

اليوم 57 - أمن الشبكات اللاسلكية (Wireless Security)

أمن الشبكات اللاسلكية هو موضوع بالغ الأهمية لأن الشبكات اللاسلكية بطبيعتها تنقل البيانات عبر الهواء باستخدام موجات الراديو، مما يعني أن أي شخص في نطاق التغطية يمكنه اعتراض الإشارة إذا لم تكن محمية بشكل صحيح. على عكس الشبكات السلكية حيث يحتاج المهاجم إلى وصول فيزيائي للكابل، في الشبكات اللاسلكية، يكفي أن يكون المهاجم في نطاق الإشارة اللاسلكية لبدء محاولات الاختراق. في هذا الدرس، سنستعرض تطور بروتوكولات الأمان اللاسلكي من WEP الضعيف إلى WPA3 القوي، بالإضافة إلى بروتوكول EAP و 802.1X و شرح مفصل لمكونات المصادقة المؤسسية. فهم هذه البروتوكولات ضروري لأي مهندس شبكات ليتمكن من تأمين الشبكة اللاسلكية بشكل صحيح وحماية بيانات المؤسسة والموظفين.

WEP أو Wired Equivalent Privacy هو أول بروتوكول أمان تم تقديمه لشبكات Wi-Fi في عام 1997. كان الاسم يوحي بأنه سيوفر خصوصية مكافئة للشبكات السلكية، لكن الحقيقة كانت مختلفة تماماً. يستخدم WEP خوارزمية التشفير RC4 بمفتاح ثابت (إما bit-64 أو bit-128) مع متجه تهيئة IV (Initialization Vector) بطول bit-24 فقط. المشكلة الأساسية هي أن IV قصير جداً ويتكرر بعد فترة قصيرة، مما يسمح للمهاجم بجمع حزم كافية لتحليل التشفير واستخراج المفتاح الرئيسي بسهولة. هناك أدوات مجانية مثل Aircrack-ng يمكنها كسر تشفير WEP في دقائق معدودة بعد جمع بضعة آلاف من الحزم. لذلك، يعتبر WEP حالياً غير آمن تماماً ولا يجب استخدامه تحت أي ظرف. أي شبكة لا تزال تستخدم WEP هي شبكة مكشوفة بالكامل للاختراق.

WPA أو Wi-Fi Protected Access كان حلاً مؤقتاً صدر في عام 2003 لمعالجة نقاط الضعف القاتلة في WEP، وذلك بينما كان معيار 802.11i قيد التطوير. يستخدم WPA بروتوكول TKIP (Temporal Key Integrity Protocol) الذي يحسن على WEP بعدة طرق. أولاً، يستخدم TKIP آلية تغيير المفتاح بشكل ديناميكي لكل حزمة (Per-Packet Keying)، مما يعني أن كل حزمة تُشفّر بمفتاح مختلف مشتق من المفتاح الرئيسي. ثانياً، يزيد طول IV إلى bit-48 بدلاً من bit-24. ثالثاً، يضيف آلية التحقق من سلامة الرسالة (MIC Message Integrity Check) لمنع التلاعب بالبيانات. رغم هذه التحسينات، اكتشفت نقاط ضعف في TKIP مع مرور الوقت، وأبرزها هجوم Beck-Tews الذي يمكنه كسر TKIP في دقائق. لذلك، WPA/TKIP يعتبر حالياً غير آمن للممارسات الحديثة، ويجب استخدام WPA2 على الأقل.

WPA2 هو المعيار الحالي والأكثر استخداماً لأمن الشبكات اللاسلكية. تم تقديمه في عام 2004 كتطبيق كامل لمعيار IEEE 802.11i. يستخدم WPA2 خوارزمية AES (Advanced Encryption Standard) في وضع CCMP (Counter Mode CBC-MAC Protocol) بدلاً من RC4 الضعيف. AES هو معيار تشفير حكومي أمريكي ويُعتبر آمناً جداً عملياً. يوفر CCMP التشفير والمصادقة والتكامل للبيانات في نفس الوقت. بالإضافة إلى AES-CCMP، يستخدم WPA2 آلية تبادل مفاتيح آمنة تسمى 4-Way Handshake لإنشاء مفاتيح التشفير المؤقتة بين العميل ونقطة الوصول. WPA2 آمن بشكل كافٍ للاستخدام اليومي إذا تم استخدام كلمة مرور قوية (طول 8 أحرف على الأقل، متنوعة). لكن يمكن أن تتعرض شبكة WPA2 لهجمات مثل هجوم هاندشيك التقاط (Handshake Capture) وهجمات القاموس (Dictionary Attack)، خاصة إذا كانت كلمة المرور ضعيفة أو شائعة. هجوم KRACK (Key Reinstallation Attack) الذي ظهر في 2017 استغل ثغرة في 4-Way Handshake نفسها، لكنه يتطلب قرباً من العميل وليس من السهل تنفيذه.

مقارنة بروتوكولات الأمان اللاسلكي:

WEP: تشفير RC4، مفتاح ثابت، 24-bit IV، غير آمن تماماً. WPA: تشفير TKIP/RC4، تغيير المفتاح لكل حزمة، 48-bit IV، ضعيف. WPA2: تشفير 4-Way Handshake، AES-CCMP، آمن مع كلمة مرور قوية. WPA3: تشفير SAE (Dragonfly)، AES-GCMP، مقاوم لهجمات القاموس.

WPA3 هو أحدث معيار أمان لاسلكي تم تقديمه في عام 2018 ويوفر تحسينات أمنية كبيرة مقارنة بـ WPA2. أهم تحسين في WPA3 هو استخدام بروتوكول SAE (Simultaneous Authentication of Equals) أو ما يُعرف بـ Dragonfly بدلاً من Way Handshake. SAE-4 يحمي من هجمات القاموس خارج الخط (Offline Dictionary Attacks) حتى إذا كانت كلمة المرور ضعيفة. كيف يعمل هذا؟ في WPA2، المهاجم يمكنه التقاط Way Handshake-4 ثم تجربة كلمات مرور مختلفة دون اتصال بالشبكة حتى يجد الصحيح. في WPA3، يستخدم SAE تبادلاً فرتييه (Frothier) آمناً (Zero-Knowledge Proof) يجعل من المستحيل تجربة كلمات المرور خارج الخط. بالإضافة إلى ذلك، يوفر WPA3 تشفير AES-GCMP (Galois/Counter Mode Protocol) الأقوى والأسرع، ويوفر WPA3-Enterprise خيار 192-bit Security Level المطابق لمعايير (CNSA (Commercial National Security Algorithm). كما يقدم WPA3 ميزة Opportunistic Wireless Encryption (OWE) للشبكات المفتوحة، حيث يتم تشفير الاتصال حتى بدون كلمة مرور. على الرغم من أن WPA3 لا يزال قيد الانتشار، إلا أنه مستقبل أمن الشبكات اللاسلكية.

لنتحدث الآن عن بروتوكول EAP أو Extensible Authentication Protocol. EAP ليس بروتوكول مصادقة واحداً، بل هو إطار عمل (Framework) يسمح باستخدام طرق مصادقة متعددة. في سياق الشبكات اللاسلكية المؤسسية، يستخدم EAP مع 802.1X لتوفير مصادقة مركزية لكل مستخدم على حدة. هناك عدة أنواع من EAP، أشهرها: EAP-TLS (Transport Layer Security) الذي يستخدم شهادات رقمية على كل من العميل والخادم، وهو الأكثر أماناً لكنه يتطلب بنية تحتية للشهادات (PKI). EAP-TTLS (Tunneled TLS) حيث يكون للخادم شهادة فقط ويتم إنشاء نفق آمن يتم فيه إرسال بيانات المستخدم (اسم المستخدم وكلمة المرور). PEAP (Protected EAP) مشابه لـ EAP-TTLS لكنه من تطوير Cisco. LEAP و Lightweight EAP)) من Cisco وهو قديم وضعيف ويجب تجنبه. اختيار نوع EAP المناسب يعتمد على متطلبات الأمان والبنية التحتية المتاحة في المؤسسة.

معيار 802.1X هو إطار عمل للمصادقة على مستوى المنفذ (Port-Based Access Control) يستخدم لكل من الشبكات السلكية واللاسلكية. يتكون 802.1X من ثلاثة مكونات رئيسية. المكون الأول هو Supplicant (المستخدم) وهو برنامج على جهاز العميل يحاول الاتصال بالشبكة، مثل Windows Wireless Client أو wpa_supplicant على لينكس. المكون الثاني هو Authenticator (المصادق) وهو نقطة الوصول أو المحول الذي يعمل كوسيط بين العميل وخادم المصادقة. المكون الثالث هو Authentication Server (خادم المصادقة) وهو عادة خادم RADIUS (Remote Authentication Dial-In User Service) مثل Cisco ISE أو FreeRADIUS أو Microsoft NPS. عندما يحاول عميل الاتصال بالشبكة، تطلب نقطة الوصول هويته، ثم تمرر معلومات المصادقة إلى خادم RADIUS، الذي يقرر قبول أو رفض الاتصال بناءً على بيانات الاعتماد أو الشهادات. إذا تم القبول، يخبر RADIUS نقطة الوصول بالسماح للعميل بالمرور.

مكونات 802.1X:

Supplicant: برنامج على جهاز العميل يطلب الاتصال. Authenticator: نقطة الوصول أو المحول التي تمرر طلب المصادقة. Authentication Server (RADIUS): الخادم الذي يتحقق من صحة بيانات الاعتماد ويقرر السماح أو الرفض.

التفرقة بين WPA2-PSK و WPA2-Enterprise هي تفرقة أساسية في أمن الشبكات اللاسلكية. WPA2-PSK (Pre-Shared Key) هو وضع المستخدم في المنازل والمكاتب الصغيرة، حيث يتم استخدام كلمة مرور واحدة (Passphrase) لجميع المستخدمين. كل شخص يعرف كلمة المرور يمكنه الاتصال بالشبكة. هذا بسيط وسهل، لكنه غير مناسب للمؤسسات لعدة أسباب: لا يمكن إلغاء وصول مستخدم معين دون تغيير كلمة المرور للجميع، وليس هناك سجل من قام بالاتصال ومتى، وكلمة المرور تدور بين عدد كبير من الأشخاص مما يزيد احتمالية تسريبها. WPA2-Enterprise يستخدم 802.1X مع خادم RADIUS، حيث كل مستخدم لديه بيانات اعتماد خاصة به (اسم مستخدم وكلمة مرور أو شهادة). هذا يسمح بإلغاء وصول مستخدم معين دون التأثير على الآخرين، وتوفير سجل كامل لكل عملية اتصال، وتطبيق سياسات أمان مخصصة لكل مستخدم أو مجموعة. للمؤسسات، يُنصح دائماً باستخدام WPA2-Enterprise أو WPA3-Enterprise بدلاً من PSK.

هناك أساليب أمان أخرى تُستخدم أحياناً لكنها لا توفر حماية حقيقية بمفردها. تصفية MAC (MAC Filtering) هي ميزة تسمح فقط للأجهزة التي عناوين MAC الخاصة بها موجودة في قائمة مسموح لها بالاتصال. المشكلة هي أن عنوان MAC يمكن تزويره (MAC Spoofing) بسهولة باستخدام أدوات بسيطة. المهاجم يمكنه التقاط حزم من الجهاز المسموح له، استخراج عنوان MAC الخاص به، ثم تغيير عنوان MAC لبطاقته اللاسلكية ليتطابق مع العنوان المسموح. لذلك، تصفية MAC توفر فقط شعوراً زائفاً بالأمان ولا تمنع المهاجم المصر. إخفاء SSID (SSID Hiding) هو أسلوب آخر حيث لا تبث نقطة الوصول اسم الشبكة. لكن كما ذكرنا في الدرس السابق، يمكن اكتشاف SSID بسهولة من حزم Probe Request و Probe Response التي ترسلها الأجهزة المتصلة بالشبكة. هذه الأساليب قد تكون مفيدة كطبقة إضافية دفاع، لكن لا يجب الاعتماد عليها كوسيلة أمان أساسية.

في الختام، أمن الشبكات اللاسلكية مجال واسع ومتطور باستمرار. يجب على مهندس الشبكات أن يظل على اطلاع بأحدث التهديدات والحلول. القاعدة الذهبية هي استخدام أحدث معيار أمان متاح (WPA3 إن أمكن، وإلا WPA2 مع كلمات مرور قوية)، واستخدام WPA2-Enterprise مع 802.1X في البيئات المؤسسية، وتجنب WEP و WPA/TKIP تماماً. كما يجب مراقبة الشبكة بانتظام للكشف عن أي نقاط وصول غير مصرح بها (Rogue APs) التي ينصبها الموظفون دون علم إدارة الشبكة، والتي تشكل ثغرة أمنية خطيرة. أدوات مثل Cisco Prime Infrastructure أو DNA Center يمكنها اكتشاف نقاط الوصول غير المصرح بها تلقائياً ومنعها من العمل. الأمان ليس منتجاً يشتريه، بل هو عملية مستمرة من المراقبة والتحسين والتحديث.